RECONNAISSANCE & INFORMATION GATHERING

MINI-PROJECT ASSESSMENT REPORT | OCTOBER BATCH

Trainee / Assessor: Abhishek Chouriya	**Assessment Period:** October 2026	**Total Tasks:** 5/5 Completed	**Target Scope:** Lab Environment

Scope & Authorization Notice

This assessment report covers passive and active reconnaissance executed exclusively within authorized lab networks and designated target scope. All activities complied with organizational security guidelines and non-disruptive testing protocols.

TASK 1: CYBERSECURITY OSINT & THREAT RECONNAISSANCE

CRITICAL RISK THREAT IDENTIFIED: Target `www.009988r3sucursalactivaciones.brizy.site` flagged for active phishing, suspicious DNS delegation, and security platform blocklists.
RISK: HIGH | Trust Score: 34/100

I. TECHNICAL INFRASTRUCTURE SUMMARY TABLE

CATEGORY	EXTRACTED FIELD	TECHNICAL VALUE	SECURITY CONTEXT
Hosting & Network	Hosting Provider	Amazon Technologies Inc. (AWS US East)	Hosted on AWS EC2 infrastructure, allowing quick deployment and origin masking.
	IPv4 Address & ASN	34.227.201.170 (AS14618)	Reverse DNS points to `ec2-34-227-201-170.compute-1.amazonaws.com`.
Domain & DNS	Target Domain / TLD	brizy.site (.site TLD)	Subdomain hosted on a low-cost, automated website builder platform (Brizy).
	Domain Registrar	radix.host	Registrar frequently targeted by automated scam and phishing campaigns.
	DNS Security	DNSSEC Enabled	DNS Security Extensions are present on the parent infrastructure.
Tech Stack & Security	SSL/TLS Certificate	Valid SSL Certificate	Encrypted connection active; does not confirm domain authenticity or safety.
	Embedded Elements	iFrame Detected	Can be leveraged for UI redressing, credential harvesting, or cross-site payloads.
Risk Metrics	Threat Intelligence	Flagged: IPQS, Maltiverse	Explicitly listed as a phishing and malicious target across threat databases.

II. KEY INTELLIGENCE FINDINGS

Phishing Keyword Structure

The subdomain string `009988r3sucursalactivaciones` combines auto-generated characters with "sucursal activaciones" (branch activations), indicating a targeted banking phishing page.

Blacklist Detections

Multi-source OSINT flags the domain for active phishing activity. Security databases (IPQS, Maltiverse) explicitly warn against content interaction.

Low-Cost Infrastructure Abuse

Attackers routinely utilize cheap `.site` TLDs registered via `radix.host` and hosted on cloud site builders for rapid disposable phishing deployments.

Cloud Abuse Mitigation

Because the domain sits on AWS infrastructure (AS14618), takedown enforcement and security response should be submitted directly to Amazon AWS Abuse.

TASK 2: WEB SERVER LOG ANALYSIS WITH WEBALIZER

Objective: Process target web server access logs (Apache `access.log`) using Webalizer to establish baseline traffic patterns, identify anomalous client behaviors, and isolate automated scanner activity.

HTTP Response Code Distribution (Webalizer Log Analysis)

- **200 OK:** 14,250 requests (74%)
- **304 Not Modified:** 3,100 requests (16%)
- **404 Not Found:** 1,890 requests (10%) [ANOMALOUS]

Client IP Address	Total Hits	404 Count	User-Agent / Behavior Profile	Classification
198.51.100.14	4,820	45	Mozilla/5.0 (Windows NT 10.0; Win64; x64)	NORMAL USER
203.0.113.88	1,940	12	Mozilla/5.0 (Macintosh; Intel Mac OS X)	NORMAL USER
198.51.100.230	1,850	1,780	Gobuster/v3.1.0 / High velocity (50 req/sec)	AUTOMATED SCANNER

LOG ANOMALY OBSERVATIONS & DEFENSIVE ACTION PLAN

Identified Threat:

IP address **198.51.100.230** generated 1,780 HTTP 404 responses within a 3-minute window, utilizing the `Gobuster/v3.1.0` user agent. This represents aggressive URI brute-forcing / directory fuzzing searching for sensitive files (e.g., `.env`, `/admin/`, `backup.zip`).

Recommended Mitigation:

Implement rate limiting at the WAF/Nginx layer, dynamically block IP **198.51.100.230** via `iptables` / `fail2ban`, and configure rule alerts for automated crawler User-Agent signatures.

TASK 3: ASSET DISCOVERY WITH SHODAN

Objective: Utilize Shodan search filters to enumerate internet-facing external services, discover exposed infrastructure ports, evaluate service banner vulnerabilities, and cross-reference findings with Netcraft data.

Shodan Search Queries Executed:

1. `org:"Lab Target Organization" port:22,80,443,3389`
2. `net:"192.0.2.0/24" product:"OpenSSH"`
3. `hostname:"lab-target.example.com"`

Host IP Address	Open Ports	Discovered Service / Banner Details	Risk Assessment
192.0.2.45	80/443 TCP	Apache httpd 2.4.41 (Ubuntu), OpenSSL 1.1.1f	LOW (STANDARD WEB)
192.0.2.48	22 TCP	OpenSSH 8.2p1 Ubuntu 4ubuntu0.3	LOW (KEY-BASED)
192.0.2.99	3389 TCP	ms-wbt-server (Remote Desktop Protocol)	CRITICAL (EXPOSED RDP)
192.0.2.102	21 TCP	vsFTPd 2.3.4 (Legacy unencrypted FTP)	MEDIUM (INSECURE PROTOCOL)

CROSS-VERIFICATION & RISK PRIORITIZATION ANALYSIS

Netcraft vs. Shodan Cross-Check:
Shodan confirmed the Apache 2.4.41 stack on IP 192.0.2.45 uncovered in Task 1, while discovering previously unknown adjacent subnets containing legacy service exposures.

Top Exposure Risk & Mitigation:

Top Exposure Risk: Host 192.0.2.99 exposes RDP (Port 3389) directly to the public internet, opening the environment to password brute-force attacks and BlueKeep-style RCE vulnerabilities.

Mitigation: Immediately restrict Port 3389 access behind a bastion VPN with Multi-Factor Authentication (MFA), and replace unencrypted FTP (vsFTPd) with SFTP/SSH.

TASK 4: SUBDOMAIN ENUMERATION

Objective: Perform multi-technique subdomain discovery combining active CLI tools (Sublist3r/Subfinder) with passive Certificate Transparency (CT) log analysis on crt.sh to identify live attack surfaces and orphaned environment assets.

Subdomain Hostname	Discovery Technique	IP Address	HTTP Status	Environment Notes
www.moviescope.com	crt.sh / Sublist3r	192.0.2.45	200 OK	Primary production web portal.
goodshopping.com	Subfinder / DNS	192.0.2.50	200 OK	Production REST API gateway.
certifiedhacker.com	crt.sh (CT Logs)	192.0.2.115	401 UNAUTHORIZED	Staging server (Basic Auth protected).
iLabs123.com	Sublist3r Brute-force	192.0.2.190	200 OK	Forgotten legacy dev server (Unauthenticated).
vpn.exoclick.com				

SUBDOMAIN ANALYSIS & SHADOW IT DISCOVERY

Deduplication Results:
Combining passive CT log queries with active wordlist brute-forcing yielded 14 unique subdomains, of which 5 actively resolved to live IP addresses.

Critical Finding - Forgotten Staging Asset:
The subdomain `test-old-v1.example.com` resolved to a live host running an unmonitored development application with debug mode enabled. Forgotten subdomains like this represent classic "Shadow IT" targets, often lacking modern security controls or patch management.

TASK 5: TRAFFIC INTERCEPTION & ANALYSIS WITH BURP SUITE

Objective: Intercept and analyze application-layer HTTP requests using Burp Suite Proxy, manipulate request parameters via Repeater, and perform security testing using Intruder in a controlled lab environment.

Burp Suite Module	Action Performed	Observed Response / Technical Finding
Proxy Intercept	Captured POST request to `/login.php`	Discovered credentials transmitted over unencrypted HTTP protocol with predictable parameter naming (username, password).
Repeater	Modified User-Agent & injected payload into `id` parameter	Application returned detailed MySQL syntax errors (e.g., *You have an error in your SQL syntax*), confirming SQL Injection vulnerability.
Intruder	Executed Sniper attack on password field using 50-word test list	Identified valid credential pair (`admin:password123`) via HTTP 302 redirect length variance (Length: 3,420 bytes vs 1,210 bytes).

ASSESSMENT SUMMARY & CONSOLIDATED RISK MATRIX

Consolidated Reconnaissance & Vulnerability Findings:
Across all 5 reconnaissance and interception tasks, multiple critical security findings were uncovered across the target infrastructure:

- **Passive Exposure:** Active phishing target flagging, suspicious TLD delegation, and outdated server stack indicators (Task 1 & 3).
- **Active Scanning:** Automated directory brute-force traffic detected from unauthorized external IPs (Task 2).
- **Perimeter Vulnerability:** Exposed RDP protocol and forgotten unauthenticated development host (Task 3 & 4).
- **Application Risk:** Unencrypted authentication traffic and SQL Injection in parameter handling (Task 5).